

Resolução das Atividades Teóricas

1. Propriedades oferecidas e lacunas: Ao cifrar a mensagem sem autenticar o remetente, o aplicativo garante apenas a confidencialidade, já que ninguém no caminho conseguirá ler o texto claro. Por outro lado, a autenticidade fica comprometida (não dá para saber quem realmente mandou) e a integridade também (não há garantia de que a mensagem cifrada não foi alterada, injetada ou trocada por um atacante no meio do trajeto).

2. Classificação dos ataques:

- **(a) Copiar tráfego: Passivo** — o atacante apenas observa os dados, sem interferir no fluxo.
- **(b) Trocar o valor de uma transferência: Ativo** — altera diretamente o conteúdo da mensagem.
- **(c) Medir horários e tamanhos: Passivo** — analisa apenas os metadados da comunicação.
- **(d) Repetir uma requisição antiga: Ativo** — injeta e reenvia mensagens no canal (*replay attack*).

3. Modelo de Ameaça para o Sistema de Notas

- **Ativo a proteger:** Os registros de notas e a integridade do boletim escolar.
- **Adversários:** Alunos tentando alterar notas ou terceiros com acesso à rede da escola.
- **Capacidades do adversário:** Interceptação de tráfego na rede local, acesso a sessões abertas de professores ou tentativa de envio de requisições adulteradas.
- **Objetivo de proteção:** Garantir que só professores autorizados consigam alterar notas (autenticidade/autorização) e que cada aluno veja apenas o seu próprio boletim (confidencialidade e controle de acesso).
- **Fora de escopo:** Quedas de energia ou indisponibilidade física do servidor/datacenter.

4. Princípio de Kerckhoffs: O princípio de Kerckhoffs defende que a segurança de um sistema criptográfico deve depender exclusivamente do segredo da **chave**, e nunca do segredo do algoritmo. Na prática, mesmo que um atacante conheça todo o projeto, o código-fonte e o funcionamento do sistema, ele não deve ser capaz de decifrar ou forjar dados se não tiver a chave secreta.

5. Cópia de Segurança vs. Integridade Criptográfica: O *backup* serve para recuperar informações após uma perda ou corrupção de dados, é uma medida defensiva e reativa. Ele não substitui a integridade criptográfica porque não consegue detectar, em tempo real, se uma mensagem ou arquivo foi alterado por um atacante durante o envio. A integridade criptográfica valida o dado no momento em que ele é recebido; o backup apenas ajuda a restaurar o que foi perdido depois do incidente.

6. Autenticidade com Chave Compartilhada: Com uma chave compartilhada, não é possível provar para terceiros qual pessoa específica enviou a mensagem. Como todos os membros do grupo possuem a mesma chave, qualquer um deles tem capacidade técnica para gerar uma mensagem válida. Existe a certeza de que a mensagem veio do grupo (autenticidade de grupo), mas não há **não repúdio** nem identificação individual.

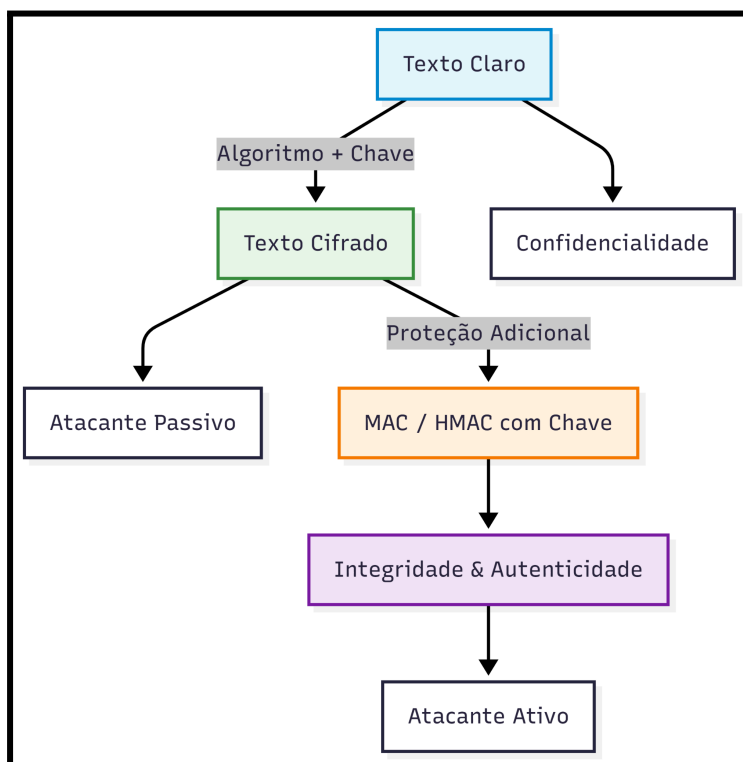
7. O que um atacante descobre analisando metadados? Mesmo com o conteúdo cifrado, observar apenas os horários e tamanhos dos pacotes permite inferir:

- A frequência e o volume da comunicação entre os participantes.
- O tipo de dado trocado (por exemplo, diferenciar mensagens curtas de texto, chamadas de voz ou envio de arquivos pesados).
- Os horários de rotina e o padrão de atividade dos usuários.

8. O ativo mais importante no sistema escolar: O ativo principal é a integridade dos registros acadêmicos. Se a confidencialidade for violada, temos um problema de privacidade; contudo, se a integridade for comprometida e as notas forem adulteradas, todo o sistema perde sua credibilidade e validade institucional.

9. Orientação correta sobre o Base64: O Base64 é apenas um padrão de codificação público, feito para converter dados binários em caracteres imprimíveis. Como qualquer pessoa pode reverter essa conversão sem precisar de uma chave, ele não oferece confidencialidade e não é criptografia. Para proteger o sigilo de uma informação, é indispensável usar uma cifra controlada por uma chave secreta.

10. Construa um mapa conceitual que relacione os conceitos essenciais deste encontro. Inclua pelo menos seis ligações explicadas:



Explicação do Mapa Conceitual

O mapa conceitual ilustra o fluxo de proteção da informação e como diferentes mecanismos criptográficos respondem a diferentes ameaças:

1. **Texto Claro → Algoritmo + Chave → Texto Cifrado:** A transformação de um dado legível (*Texto Claro*) em uma mensagem ininteligível (*Texto Cifrado*) depende da aplicação de um algoritmo controlado por uma chave secreta.

2. **Texto Claro → Confidencialidade:** O objetivo direto de cifrar o texto claro é garantir a *Confidencialidade*, impedindo que partes não autorizadas leiam o conteúdo original.
3. **Texto Cifrado → Atacante Passivo:** A garantia da confidencialidade neutraliza a ação do *Atacante Passivo*, que apenas observa o canal de comunicação sem alterar o conteúdo.
4. **Texto Cifrado → Proteção Adicional → MAC / HMAC com Chave:** Cifrar a mensagem protege o sigilo, mas não impede sua alteração; por isso, adiciona-se um autenticador com chave (*MAC/HMAC*) para proteções adicionais.
5. **MAC / HMAC com Chave → Integridade & Autenticidade:** A verificação do HMAC assegura que a mensagem não foi modificada no caminho (*Integridade*) e que foi gerada por quem possui a chave secreta (*Autenticidade*).
6. **Integridade & Autenticidade → Atacante Ativo:** Ao validar a origem e a inalterabilidade da mensagem, o sistema impede o sucesso do *Atacante Ativo*, que tenta injetar, adulterar ou retransmitir dados no canal.